SCRIWO

Every conversation, *thoughtfully handled.*

Product overview: what Scriwo is, every feature it has today, where it is outstanding, and where it is weak.

Candid internal edition: for the team, not for customers

Version 1.0 · 27 October 2026

Facts read from the code, the tests and the live system on this date

1 · AT A GLANCE

What Scriwo is

Scriwo is a **shared WhatsApp inbox with a built-in CRM**, sold as a subscription to companies in India and the UAE. A company links its own WhatsApp numbers by scanning a QR code, and then its whole team answers customers from one calm screen: assigning chats, leaving private notes, running follow-ups, sending permission-based broadcasts, tracking leads through a sales pipeline and getting AI help with replies.

10
screens in the app's sidebar, from Inbox to Developers

5
plans: Free, Starter, Growth, Business, Enterprise

941
automated tests (493 backend, 448 app) plus 38 for the website

29
database migrations, 56 tables, about 175 API handlers

Three products in one system

1. The workspace app

app.scriwo.com. What a company's team uses every day: inbox, numbers, contacts, pipeline, broadcasts, automations, reports, team, plan and billing, developer tools. React 19 on Vercel.

2. The platform console

Inside the same app, for the Scriwo team only (super admin). Create companies, set prices and limits, tick which modules each plan gets, record payments, watch number health and books, see website enquiries.

3. The website and shop

www.scriwo.com. Marketing in English, Arabic and Hindi, live prices, and a checkout where a visitor pays with Razorpay and receives a workspace automatically. Next.js 15 on Vercel.

Live state on 27 October 2026

PART	STATE READ FROM THE LIVE SYSTEM
API	Version 3.0.0, API contract 3, build `9f224ec`, database connected (PostgreSQL), schema `028_website_checkout`, 5 WhatsApp numbers connected and running.
Payments	Razorpay is configured in **live mode**: real money moves. The signed webhook, the reconciliation job, GST invoices and the website checkout are built and enabled.
Email, AI, media	Resend sends from `noreply@scriwo.com`; Riwo runs on OpenRouter free models; private S3-compatible media storage is configured.
Built, not yet deployed	**Forgot password** (migration 029): finished and tested on 27 October, waiting for the release that follows this document.

How to read this document
Features listed exist in the code and are covered by named automated tests unless marked BUILT, NOT DEPLOYED. Where a promise on the website or in an old document does not match the product, this document says so.

The honest verdict

Scriwo is a **well-built, well-tested product** with a business layer (billing, GST, plan control, website checkout) that many young WhatsApp tools lack. Its biggest risks are not code quality: it runs on an **unofficial way of talking to WhatsApp**, from a **single server**, and the **live-money path has never been exercised with a real purchase**.

What is strongest

- **A real team inbox with CRM depth**: assignment rules, private notes, follow-ups with escalation, reply-time reports, a lead pipeline, AI help.
- **India-first money handling**: Razorpay, gapless GST invoices (CGST + SGST or IGST), editable service code and tax rate, buy-from-website that creates the workspace.
- **Plans are data, not code**: the super admin changes prices, limits and module access without a release, and customers see the lock or unlock live, with a notification.
- **Server-side enforcement** of roles, plans and tenant isolation, proved by tests that were broken on purpose to confirm they fail.
- **Safe by design** broadcasts: opt-in only, STOP and SUBSCRIBE honoured, paced sending.

What worries us most

- **WhatsApp can break or ban this approach.** There is no official WhatsApp Business Platform option today.
- **One server, one browser worker.** No staging environment, no monitoring or alerting, and a restore of the backup has never been rehearsed.
- **The first real purchase has not happened.** The accountant has not yet confirmed the invoice fields or the service code. Refunds do not remove access by themselves.
- **AI runs on shared free models** with a small daily ceiling for the whole account, and the key used was exposed in chat and must be replaced.
- **Promises have drifted**: live plan tick-boxes, the website's plan lists and older documents no longer agree in places.

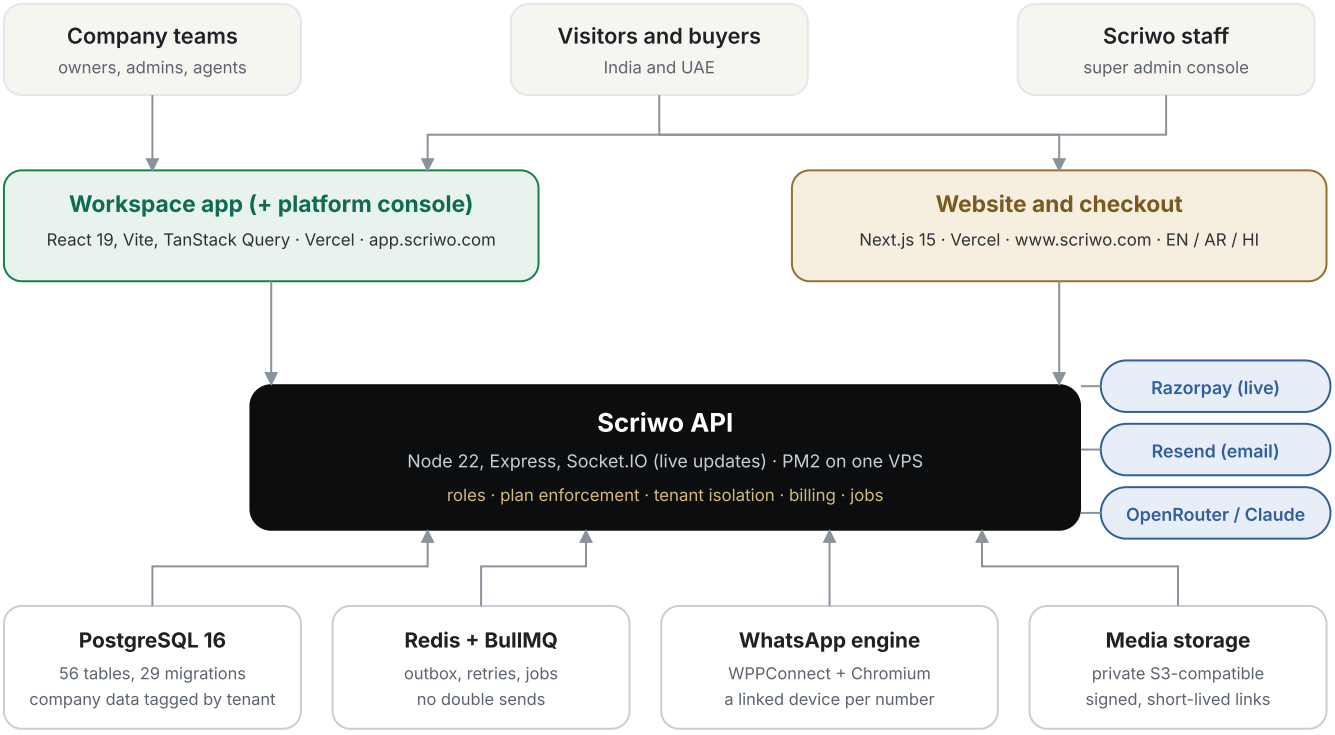
The five things to do next, in order

#	ACTION	WHY IT COMES FIRST
1	**Run one real ₹1 purchase** end to end, then refund it and issue the credit note.	Payments are proven against a simulation only. This is the cheapest test of the live gateway.
2	**Have the accountant confirm** the invoice fields and service code (SAC 998314 is the default; 997331 is the one most often cited for SaaS).	Invoice numbering is gapless: a wrong field cannot be quietly fixed afterwards.
3	**Rotate secrets**: the AI provider key shared in chat, and the super-admin password created by migration 004.	Both are known to be exposed or guessable. Five minutes of work.
4	**Add a staging copy, uptime and error alerts, and rehearse a database restore.**	All conversations live on one server. A restore nobody has tried is not a backup.
5	**Decide the WhatsApp strategy**: keep the linked-device engine, add the official Cloud API as a second option, or both.	The biggest business risk, and the only one code cannot fix in a day.

3 · HOW IT IS BUILT

Architecture at a glance

Two front ends talk to one API. The API owns the database, the queue, the WhatsApp browsers and every outside service. Each company's data is separated by a tenant identifier on every company-owned row, enforced on the server.



Why it is built this way

CHOICE	WHAT IT GIVES, AND WHAT IT COSTS
Linked-device WhatsApp engine	A company can start in minutes with the number it already uses, no application to Meta, no per-message fee. The cost is dependence on how WhatsApp Web behaves (see the risks chapter).
Outbox with receipts	Every outgoing message is written to the database first, then sent by a worker. A provider ID is stored so the same message is never sent twice, and an uncertain send is never retried automatically.
One PostgreSQL, tenant on company data	Simple to run and to back up. Isolation depends on every query carrying the tenant, which a dedicated test file (`tenant-isolation.test.js`) checks across the API.
Plans stored in the database	Prices, limits and module ticks are edited in the console, not shipped as code. The server reads them on every request, so a change applies at once.
Frontend and backend released separately	The frontend release is held by a check that the backend is healthy and speaks the same API contract, so a half-deployed release cannot reach customers.

4 · EVERY FEATURE

The feature catalogue

One card per module, in the order a customer meets them. The right-hand column says who can use it, which plan unlocks it and the honest limits.

Shared inbox and chat LIVE

Every plan · all roles

- One live inbox across every linked number. New messages and delivery ticks (sent, delivered, read) appear with no refresh; a dropped connection is caught up and a periodic repair job fills any gap.
- Opening a chat loads its earlier WhatsApp history. Groups appear as groups; status updates stay out of customer chats.
- Photos, video, voice notes and documents (up to 16 MB for media and 64 MB for documents), stored privately and served by short-lived signed links.
- Assign to a teammate, resolve, **private notes** that are never sent, and **@mentions** that notify the person.
- Saved replies, pinned chats, coloured labels with filters, waiting and overdue filters, a warning when a teammate is already writing a reply, and **New chat** to any typed number.
- Command palette for quick navigation; light and dark themes; desktop and offline alerts so a message is not missed.

WHO SEES WHAT

Agents see chats on their own number plus chats assigned to them. Owners and admins see everything. Enforced on the server.

GOOD TO KNOW

"Delivered" means WhatsApp accepted it, not that a person read it. No calls, reactions, or editing and deleting of sent messages.

Numbers: connecting WhatsApp LIVE

Owners and admins · limit set by plan

- Link a number by scanning a QR code (manager-only). Each company has a number limit from its plan: 1, 3, 10, 25, or custom.
- Sessions recover after a server restart. Each number has its own isolated browser profile.
- **Number health**: a heartbeat plus failed and waiting sends; owners and admins are alerted when a phone goes offline or sends are failing.
- Removing a number unlinks it, deletes its saved login and cleans up leftover browser processes. A number can be given an owner, and an inbox re-sync can be forced.

PLAN

Free 1, Starter 3, Growth 10, Business 25, Enterprise custom (the super admin must type the number).

GOOD TO KNOW

The live heartbeat asks WhatsApp Web whether it is connected; its accuracy still has to be watched on the live server.

Team, roles and assignment LIVE

Owners and admins manage

- Roles: **owner, admin, agent**, plus the Scriwo-side super admin. Team members can have a category (general, sales, support, billing, operations or marketing). Suspending a person drops their live sessions at once.
- Invitations by email: a single-use link, 24 hours, resendable and revocable. Passwords are never emailed. A person who already has an account must prove their current password to join another company.
- **Automatic assignment** of new chats: in turn (round robin) or to the least busy person, with an away switch, working hours, per-person limits, and returning customers going back to the same person.
- **Audit log** of sensitive actions. Staff never see billing.
- **Forgot password** on the sign-in page: a one-hour, single-use emailed link; the same answer whether or not the address has an account; every device is signed out after a reset. BUILT, NOT DEPLOYED

PLAN

Team and roles on every paid plan; Free is one person. Audit log from Growth (as ticked in the console).

GOOD TO KNOW

No two-factor sign-in and no single sign-on yet.

Contacts and consent LIVE

Every plan

- Contacts built from conversations, CSV import and export, tags and custom traits. WhatsApp's own name is kept apart from the name your team gives a contact.
- **Recorded opt-in** with a confirmation step for contacts nobody has decided on. A customer's STOP is never overridden. A CSV `optin` column records permission and never undoes a STOP.
- Customers manage themselves: **STOP** removes them from broadcasts (the chat stays open for staff); **SUBSCRIBE** puts them back.
- Bulk "add to pipeline" from the contact list.

PLAN

A contact limit can be set per plan and is enforced with a warning from 80%. No plan has one today.

GOOD TO KNOW

A customer's message is never refused because of a limit.

Broadcasts STARTER AND UP (AS TICKED TODAY)

Owners and admins

- A **three-step wizard**: message, audience, review. Ten ready-made messages, a live preview and the audience counted before anything is sent.
- A message with an unfilled `[blank]` or an unknown `{{field}}` is refused. `{{first_name}}`, `{{name}}` and `{{company}}` are filled per person; someone known only by phone number is greeted as "there".
- Send now, schedule, save a draft, or copy an earlier broadcast. Sending first checks the number is connected and that someone would receive it.
- **Opt-in only**: consent is re-checked before every single send. A minimum of four seconds between messages; pause and stop at any time.

PLAN

The website says Growth and up. The live plan table ticks Broadcasts from Starter. See the drift note in chapter 5.

GOOD TO KNOW

Nothing in the tests sends to real WhatsApp; delivery uses the separately tested outbox path. A monthly broadcast limit exists but none is set.

Automations GROWTH AND UP

Owners and admins

- **14 ready-made rules** in four groups, with keywords in English, Arabic and Hindi. They start paused so nothing fires by surprise.
- Triggers: a keyword (contains, whole word or exact), a customer's first message, or a message outside opening hours.
- Actions: reply, assign, add a tag, record permission, or create a lead.
- Safety rails: one automatic reply per message, a wait between repeats, at most six an hour per chat, and group chats are never answered. Each execution is recorded once.

PLAN

Growth and above.

GOOD TO KNOW

Rules are keyword-based, not conversational. There is no visual flow builder.

Sales pipeline (the CRM part) STARTER AND UP (AS TICKED TODAY)

Agents see their own · managers see all

- A **lead** is one sales opportunity for one contact; a contact has one open lead at a time. Add from a chat in one tap, from contacts, in bulk, or automatically for new customers and people asking for a quote. Never from groups.
- A **board** (a column per step, with counts and values), a **list** and a **Today** list of follow-ups. Steps can be renamed, reordered and added; templates for real estate, car dealers and clinics.
- Moves are recorded; a lost lead asks why; winning, losing and reopening are handled. Value and currency per lead.
- **Follow-ups** remind the owner once when due, escalate when overdue, and follow the chat's assignee. Won, lost and deleted leads send no reminders.
- Riwo can suggest a title, value, next step and follow-up; nothing is saved until a person confirms.

PLAN

The app labels it Growth; the live plan table ticks it from Starter.

NOT BUILT YET

Win-rate reports, "no reply in two days" alerts, broadcasts to a step, lead webhooks, custom fields, more than one pipeline. The pricing page does not mention the pipeline.

Riwo, the AI assistant GROWTH AND UP (TICKED ON FREE TODAY)

Agents, admins, owners

- **Suggest a reply** from the conversation, **improve a draft**, **translate into 15 languages**, and **summarise** a chat including how the customer sounds (mood).
- Suggests a lead's title, value and next step. The customer's phone number is never sent to the model; nothing is saved until a person confirms.
- Runs on OpenRouter's free models, ranked from the live catalogue with automatic fallback to the next model when one fails or is rate-limited; it can also run on Claude when a key is set.
- **Daily allowance per company** (server default 300, adjustable by the super admin), with usage shown to owners and admins and, per company, in the console.

PLAN

Growth and above on the website; the live plan table also ticks it on Free.

GOOD TO KNOW

Free models cap the whole account (about 50 requests a day without credit, 1,000 with $10), far below the sum of what companies may use. Quality varies by model.

Reports and dashboard LIVE

Owners and admins

- Workspace dashboard with measured aggregates (conversations, messages, activity).
- **Reply-time reports**: median and 90th percentile, the share answered inside a target, a team **leaderboard**, waiting chats, drill-down to individual episodes, and CSV export.
- An **owner daily summary** with the chats that need attention; the response target is configurable.

GOOD TO KNOW

No revenue or win-rate reporting yet, because the CRM does not have those fields.

Notifications and live updates LIVE

Everyone

- In-app bell for assignments, @mentions, offline numbers, failing sends, renewals (14 days ahead) and module changes. Optional desktop notifications.
- A live "plan changed" event so a lock or unlock appears in an open browser without a refresh, and again after a reconnect.

GOOD TO KNOW

Renewal and overdue reminders are in the app only; they are not emailed yet.

Developers: API, keys and webhooks BUSINESS AND UP

Owners and admins

- **Scoped API keys** (inbox, contacts, sessions), shown once, stored only as a hash, revocable one at a time.
- **Signed webhooks** to public HTTPS addresses: every delivery carries an `X-Scriwo-Signature`, with a delivery log and retries.
- Documentation page, an API tester and SDK samples.
- On Free, Starter and Growth the module stays in the navigation with a lock and an explanation of what the Business plan adds, and the server refuses its routes.

GOOD TO KNOW

Signed webhooks have no dedicated automated test yet. There is no lead scope for keys and no lead webhook.

Plan, payments and GST invoices LIVE (REAL MONEY)

Owners and admins

- Companies see their plan, billing cycle, renewal date, AI use, every payment and every invoice, and can **pay online with Razorpay**. An upgrade credits the unused days of the current plan.
- **Server-side pricing**: the price, credit and 18% GST are worked out on the server; the browser never states a price.
- **Exactly-once settlement**: a payment activates a plan once however many times the browser, the signed webhook and the reconciliation job report it, in any order. A wrong amount, currency, company or signature activates nothing.
- **GST tax invoices** as PDF: gapless numbers like `SCZ/26-27/00001` (16 characters, a new series each April), CGST + SGST in the seller's state and IGST elsewhere, reverse-charge statement, and the buyer's GSTIN.
- Opt-in **autopay** for monthly plans; downgrade at period end; a **7-day grace** after the renewal date, then the company behaves as Free (nothing is deleted; paying restores everything at once).

GOOD TO KNOW

All of this is tested against a simulated Razorpay; no real purchase has been made. A refund or chargeback does not remove access by itself. AED cannot be paid online yet.

Platform console (super admin) LIVE

Scriwo staff only

- **Companies**: create a company, choose its plan, number limit and AI allowance; the owner receives a 72-hour set-password link (resendable). Suspend or reactivate, change plan, schedule a change for the period end.
- **Subscriptions module**: *Rates* (monthly and yearly prices in INR and AED, tax added or included, on sale or not, with a preview), *Services & limits* (name, numbers, people, contacts, broadcasts a month, and a tick-box per module), *Invoice & tax* (service code, GST rate, prefix, seller name, GSTIN with checksum, address, upgrade credit), and *Change history*.
- Ticking or unticking a module locks or unlocks it at once for every company on that plan, and the owners and admins are notified of what changed. Issued invoices keep the details they were issued with.
- Totals and every company's number health; billing audit; online-payment view; manual payments with invoice; a logged **support access** that the company can read; and the inbox of website enquiries.

GOOD TO KNOW

The five plans are fixed; their contents are editable but a brand-new plan cannot be added without a release.

Website, shop and content LIVE

Public

- **Buy from the website**: choose a plan, enter company and invoice details with a live GST quote, pay with Razorpay, and the company, its owner, the tax invoice, a setup email and a receipt are created together once the payment is confirmed. An email that already has an account is turned away before any money is taken.
- Prices, number limits, tax mode and GST rate are **read live from the product** (refreshed every five minutes), with a built-in fallback if the product cannot be reached.
- About 80 pages: 13 blog posts, 18 city pages, 12 feature pages, 10 industry pages, 6 comparison pages, a Riwo page, a security page, legal pages, and Arabic and Hindi home pages.
- Built for discovery: structured data, `llms.txt` for AI assistants, IndexNow pings, and analytics that wait for the visitor's consent.
- A contact form that stores the enquiry and emails the team.

GOOD TO KNOW

Plan feature lists and any sentence quoting a price in blog, FAQ and comparison pages are written by hand and do not follow the live catalogue.

Security and sign-in LIVE

Everyone

- Passwords hashed with bcrypt; 1-hour access tokens kept in memory; rotating refresh tokens in an HttpOnly cookie, stored only as hashes. Reusing a revoked refresh token signs the account out everywhere.
- Sign-in and account endpoints are rate limited. Tenant isolation, roles and plan locks are enforced on the server and covered by tests.
- Support access is written down and visible to the company. Webhook addresses must be public HTTPS. The website sends a content security policy.

NOT THERE YET

Two-factor sign-in, single sign-on, IP allow-lists, and an independent security review.

Operations and delivery LIVE

The team

- Pushing to `main` triggers a deploy script on the server: one deploy at a time, exact dependencies, a database backup (best effort), migrations in a transaction with a lock timeout, restart, health check, and **automatic rollback** if any step fails.
- GitHub Actions run the backend tests (against real PostgreSQL and Redis) and the app's lint, type check, tests and build on every change. Tests create and drop their own disposable databases.
- The frontend release is held unless the backend is healthy and speaks the same API contract. `/health` reports build, schema version, payments, email, AI and active numbers.

NOT THERE YET

A staging environment, uptime and error alerting, a rehearsed restore, and branch protection on `main`.

5 · WHAT CUSTOMERS PAY

Plans, prices and modules

Scriwo charges **per company, with a number limit and no per-message fee**, not per seat. A year paid in advance costs ten months. Prices below are read from the live catalogue on 27 October 2026 and exclude tax (18% GST in India, 5% VAT in the UAE).

PLAN	NUMBERS	INDIA, MONTH	INDIA, YEAR	UAE, MONTH	UAE, YEAR
Free	1 (one person)	₹0	₹0	AED 0	AED 0
Starter	3	₹2,499	₹24,990	AED 299	AED 2,990
Growth	10	₹6,999	₹69,990	AED 799	AED 7,990
Business	25	₹14,999	₹1,49,990	AED 1,699	AED 16,990
Enterprise	Custom	Quoted by the team; set up through onboarding			

Example: Growth monthly in India is ₹6,999 + 18% GST (₹1,259.82) = ₹8,258.82, split as CGST 9% + SGST 9% in the seller's state (Uttar Pradesh) or IGST 18% elsewhere. Buying from the website works in rupees for Starter, Growth and Business; Free, Enterprise and anything in AED are still set up by the team.

Which modules each plan has, as the live catalogue stands today

MODULE	FREE	STARTER	GROWTH	BUSINESS	ENTERPRISE
Inbox, numbers, contacts, notes, assignment	✓	✓	✓	✓	✓
Broadcasts	—	✓	✓	✓	✓
Sales pipeline	—	✓	✓	✓	✓
Automations	—	—	✓	✓	✓
Audit log	—	—	✓	✓	✓
Riwo AI assistant	✓	—	✓	✓	✓
API keys and webhooks (Developers)	—	—	—	✓	✓

Drift to fix: the live ticks and the public promises disagree

The website's plan lists and the claims audit say Starter has no broadcasts, that the pipeline starts at Growth, and that Riwo starts at Growth. The live tick-boxes give Starter Broadcasts and the Pipeline, and give Free the AI assistant. Either the ticks or the website copy has to change. This matters twice over: customers are being promised less than they get on Starter, and Free users spend the shared free-model AI quota that is already tight.

How a subscription behaves

Renewal

Each company has a billing cycle and period dates. Owners see "Renews on"; owners and admins get one in-app notice 14 days before. Upgrades apply at once with credit for unused days; downgrades can be scheduled for the end of the period.

Late payment

The company is flagged and told. Seven days after the renewal date its paid modules switch off and it has what Free has. Nothing is deleted. Paying brings everything back immediately.

Limits

A plan can cap contacts and broadcasts started in a month. The server enforces it and warns from 80%. A customer's incoming message is never refused. No plan has a cap today.

Changing a plan's modules

The console shows what will lock or unlock and for how many companies before saving; afterwards the owners and admins of those companies are notified, and open browsers update without a refresh.

6 · WHERE SCRIWO STANDS OUT

What is genuinely outstanding

These are the points that set Scriwo apart from a typical "WhatsApp inbox", each tied to something you can check in the code or the tests, not to marketing.

1 It sells itself, and bills like an Indian business

A visitor can pay on the website and receive a working workspace, a GST invoice and a setup email without anyone on the team touching it. Invoice numbers are gapless and fit the 16-character legal limit, the tax split is correct for the buyer's state, and the service code, rate and seller details are editable but frozen on invoices already issued. Most small WhatsApp tools stop at "contact us".

2 Money moves exactly once

The browser, the signed webhook and a reconciliation job can all report the same payment, in any order, and the company is still activated once. A tampered signature, wrong amount or failed payment changes nothing. These checks were deliberately broken during development to prove the tests fail when they should.

3 Plans are a control panel, not a release

Prices, limits and module access are edited in the Subscriptions module. A tick or untick locks or unlocks the module for every paying company at once, tells their owners what changed and which plan to pick, updates open browsers live, and updates the website's prices within five minutes.

4 It behaves like a team tool, not a shared phone

Private notes the customer can never see, @mentions, automatic assignment (round robin or least busy, with hours and an away switch), "someone is already writing" warnings, waiting and overdue filters, follow-ups that escalate, and reply-time reports with a leaderboard. Staff only see their own number's chats and what is assigned to them.

5 A CRM that lives inside the conversation

A lead is created from a chat in one tap, shares an owner with the chat, reminds once when a follow-up is due, and can be pre-filled by AI that the person must confirm. Real estate, car dealer and clinic templates make the first setup a two-minute job.

6 Riwo is cautious by design

It suggests, improves, translates (15 languages) and summarises with the customer's mood, but never sends anything itself, never sends the customer's phone number to the model, shows each company its daily use, and falls back across several free models when one fails. The cost to the business today is close to zero.

7 Consent is built in, not bolted on

Broadcasts only reach opted-in people, consent is re-checked before every message, STOP and SUBSCRIBE are understood in three languages, messages are paced, and a broadcast cannot go out with an unfilled blank. This protects customers' numbers from the very thing that gets WhatsApp numbers banned.

8 Unusually strong engineering discipline for the size

941 automated tests across backend and app, written against real PostgreSQL with throw-away databases; tenant isolation, plan locks and payment safety each have dedicated tests; migrations fail fast instead of freezing the app; every deploy backs up, health-checks and rolls itself back.

9 A website that works as a growth channel

Around 80 pages including 18 city pages, 10 industries and 6 comparisons, Arabic and Hindi versions, structured data and an `llms.txt` so AI assistants can describe the product correctly, consent-aware analytics, and live prices that cannot go stale.

10 It admits what it is not

There is a standing audit (`docs/website-claims-audit.md`) that checks every website promise against the code and says "Test", "Code", "Service" or "Known gap" for each. When the product did not match the copy, the copy was corrected, including the sign-in wording found while preparing this document.

7 · THE OTHER SIDE

Pros, cons and risks

Pros

- Fast start: a company links the number it already has; no Meta approval.
- No per-message fees, and pricing per company, not per seat.
- Complete commercial layer: online payment, GST invoices, renewals, grace, plan control.
- Deep team features and a lead pipeline in one product.
- Consent and pacing built in.
- Extensive tests and an automatic rollback on bad deploys.
- Low running cost: free AI models and a single server.
- Bilingual website and live prices; strong search and AI-discovery groundwork.
- Open developer surface: scoped keys and signed webhooks.
- Honest documentation habit.

Cons

- Unofficial WhatsApp engine: breakage and ban exposure.
- No official templates, green tick or WhatsApp Business Platform option.
- Single server and a single browser worker; no staging, alerts or rehearsed restore.
- No two-factor sign-in or single sign-on.
- AI limited by shared free quotas.
- No native mobile apps (the web app is responsive).
- The CRM is basic: one pipeline, no custom fields, no win-rate reports.
- Rules are keyword-only; no visual flows or chatbot.
- App interface is English only (only the website is in Arabic and Hindi).
- Refunds and credit notes are manual.

The risks, ranked

1. WhatsApp dependence HIGH

Scriwo drives WhatsApp Web through an unofficial library. A WhatsApp update can break sending or the QR login without warning, and WhatsApp's terms do not allow this kind of automation, so a customer's number can be restricted. Because customers' livelihoods run on those numbers, one wave of bans would damage trust faster than any bug.

Reduce it: keep the consent-first broadcast rules and pacing, tell customers plainly in the terms, watch the library's releases, and plan an official Cloud API channel as a second option.

2. One server holds everyone's conversations HIGH

The API, the database and every WhatsApp browser run on one VPS, with one worker. The database backup is best effort (skipped if `pg_dump` is missing) and has never been restored as a test. There is no staging environment and no alerting. A disk failure, a memory spike from Chromium or a bad deploy at the wrong hour would be noticed by customers first.

Reduce it: an uptime monitor and error alert this week; a nightly off-server backup; one rehearsed restore; then a staging copy.

3. Live money without a live test HIGH

Razorpay is in live mode, but every payment path has only been proven against a simulation. The accountant has not confirmed the invoice fields or the service code, and a wrong tax invoice cannot be quietly corrected because numbering is gapless. A refund or chargeback does not remove access by itself. A test purchase uses a number in the real invoice series.

Reduce it: one ₹1 purchase, refund and credit note; confirm the three Razorpay webhook events (`payment.captured`, `payment.failed`, `order.paid`) arrive; accountant sign-off first.

4. Secrets and defaults MEDIUM

The AI provider key was shared in a chat and must be replaced. The super-admin password created by migration 004 is a known default. There is no branch protection on `main`, and pushes to `main` deploy straight to production.

Reduce it: rotate both secrets, require a pull request and the CI check before merging.

5. AI capacity and quality MEDIUM

Free OpenRouter models cap the entire account, around 50 requests a day without credit, while each company is allowed 300 a day. A handful of busy companies would exhaust it, and Free-plan users currently have the assistant. Answer quality changes with whichever model is available.

Reduce it: add credit, set per-plan allowances (planned), or move Riwo to a paid model for the top plans.

6. Promise drift MEDIUM

Live module ticks, the website's plan lists, older documents (the backend README still says billing and email are not implemented; `website-plan.md` is stale) and hand-written price sentences in blog, FAQ and comparison pages no longer agree everywhere. Terms and refund wording have not had a legal review. UAE VAT invoicing is not built, and AED cannot be paid online.

Reduce it: settle the module ticks, refresh the two stale documents, have the legal pages reviewed.

7. Key-person and scale LOW TODAY, RISING

Almost everything is understood by one builder and one assistant. The tests make this safer than it sounds, but support, on-call and security review do not yet exist as roles. Performance beyond a few dozen numbers on one worker has not been measured.

Reduce it: a short runbook, a load test at 25 and 50 numbers, and a named second person who can deploy.

Where the code is better than the risk list suggests

Most of the risks above are about operations and strategy, not code quality. The code has the habits that make operational fixes cheap: migrations that fail safely, health checks that gate releases, tests that run on disposable databases, and a deploy that rolls itself back.

Open items and next steps

Before the first paying customer

	ITEM	DETAIL
☐	**Live ₹1 purchase**	Buy through the website, confirm the workspace, invoice, setup email and receipt arrive, then refund and issue the credit note. Confirm the Razorpay dashboard shows the webhook events.
☐	**Accountant review**	Invoice fields, service code (default 998314), GST rate and seller details, including the 16-character number format.
☐	**Rotate secrets**	The AI provider key shared in chat; the migration-004 super-admin password.
☐	**Settle the plan promises**	Decide whether Starter really has Broadcasts and the Pipeline and whether Free should have Riwo; then make the ticks and the website lists say the same thing.
☐	**Legal review**	Terms, refund and shipping policy wording, particularly cancellation, the 7-day grace and WhatsApp-related disclaimers.
☐	**Deploy Forgot password**	Built and tested; ship backend first, wait for the health check to show schema 029, then the frontend.

Within the first month

	ITEM	DETAIL
☐	**Monitoring and backups**	Uptime and error alerts; nightly off-server database backup; rehearse one restore on a separate machine.
☐	**Branch protection**	Require a pull request and the CI check on `main` in both repositories.
☐	**Staging environment**	A second small server and database, so a payment or migration change can be tried without customers.
☐	**Riwo capacity**	Add credit to the AI provider or set per-plan daily allowances shown on the pricing page.
☐	**Refresh stale documents**	Backend README (it predates billing and email), `docs/website-plan.md`, and the Railway file that no longer describes where the API runs.
☐	**Email the renewal reminders**	Owners get reminders in the app only today; add email, and a weekly list of renewals and overdue companies for the sales inbox.

Product roadmap candidates (highest value first)

1. **Official WhatsApp Cloud API channel** alongside the linked-device engine, with approved templates.
2. **Two-factor sign-in** for owners and admins.
3. **CRM depth**: win-rate and revenue reports, "no reply in two days" alerts, custom fields, more than one pipeline, broadcasts to a pipeline step, lead webhooks and a key scope for leads.
4. **Refund and chargeback handling** that removes access and issues credit notes automatically.
5. **UAE**: an online payment gateway for AED and VAT invoices.
6. **Pricing page and feature pages** for the pipeline, which today has no mention on the public site.
7. **Arabic and Hindi in the app**, not only on the website.

> **A note on how this document was prepared**
> Counts (tests, tables, endpoints, pages) were taken from the repositories on 27 October 2026. Plans and prices were read from the live public catalogue, and the system status from the live health endpoint. Feature statements come from the code and the named tests in `docs/website-claims-audit.md`. Nothing in this document is based on a real WhatsApp send or a real payment, because neither has been exercised in tests or in a rehearsal.

APPENDIX

The numbers and the stack

Size and tests

MEASURE	VALUE
Backend source (JavaScript)	16,425 lines
Backend tests	10,335 lines, 51 files, 493 tests passing
App source (TypeScript)	19,447 lines
App tests	42 files, 448 tests passing
Website tests	3 files, 38 tests passing
Database migrations / tables	29 / 56
API route files / handlers	19 / about 175
Website content	13 posts, 18 cities, 12 features, 10 industries, 6 comparisons

Technology

LAYER	USED
API	Node 22, Express, Socket.IO, BullMQ, ioredis, pdfkit, sharp
Data	PostgreSQL 16, Redis, private S3-compatible storage
WhatsApp	WPPConnect 2.3.4 on Chromium
Auth	bcrypt, JWT, rotating hashed refresh tokens
Payments, email	Razorpay (orders, signed webhooks, autopay), Resend
AI	OpenRouter free models; Claude optional
App	React 19, Vite, Tailwind, TanStack Query, Vitest
Website	Next.js 15 (App Router), structured data, GA4 consent mode
Delivery	GitHub Actions, Vercel, PM2 and a deploy script on a VPS

Main data the system keeps

AREA	TABLES
Companies and people	tenants, users, memberships, invitations, password_resets, refresh_tokens, audit_events, support_access, support_access_log
Conversations	whatsapp_sessions, contacts, conversations, messages, message_receipts, attachments, outbox_events, labels, contact_labels, canned_replies, notifications
Growth tools	campaigns, campaign_recipients, consents, suppressions, automations, automation_executions, pipelines, pipeline_stages, leads, lead_tasks, lead_activities, assignment_settings, team_sla, report_settings, ai_usage
Money	plans, plan_prices, plan_changes, billing_settings, billing_settings_changes, billing_profiles, payment_orders, payments, payment_refunds, invoices, invoice_counters, subscription_payments, subscription_events, autopay_subscriptions, razorpay_plans, gateway_webhook_receipts, early_receipts
Developers and website	api_keys, webhook_endpoints, webhook_deliveries, website_leads

Roles and who can do what

ROLE	CAN
Agent	Work chats on their own number and chats assigned to them; notes, replies, their own leads and follow-ups. No billing, no team, no broadcasts.
Admin	Everything an agent can, plus all chats, numbers, contacts, broadcasts, automations, reports, team invitations for agents, the audit log, plan and billing views.
Owner	Everything an admin can, plus inviting and managing administrators.
Super admin	Scriwo staff only: the platform console, across every company.